

Nessus — Study Guide

Nessus is the industry-standard commercial vulnerability scanner (by Tenable) — the tool most VAPT engagements actually run for the "automated vulnerability scan" phase, distinct from everything you've studied so far which was mostly manual/targeted enumeration.

1. What Nessus Actually Does

Nessus performs **credentialed and uncredentialed vulnerability scanning** — it checks a target against a massive, continuously updated database of known vulnerabilities (CVEs), misconfigurations, missing patches, and weak configurations, then produces a prioritized report.

Nmap/NSE → tells you what's open and does spot-checks
Nessus → runs thousands of specific vulnerability checks (plugins) automatically

2. Versions

Version	Notes
Nessus Essentials	Free, limited to 16 IPs — good for home lab/learning
Nessus Professional	Paid, unlimited IPs, full plugin feed, used in real engagements
Nessus Expert	Adds external attack surface, cloud scanning

For your study/portfolio purposes, **Nessus Essentials** is the one to install — free, and functionally identical for learning the workflow.

3. Credentialed vs. Uncredentialed Scanning

This is the single most important concept in Nessus (and vulnerability scanning generally):

	Uncredentialed	Credentialed
Access	External view only, like an attacker with no creds	Logs in with provided creds (SSH/WinRM/SMB)

	Unauthenticated	Credentialed
Depth	Surface-level — banner grabbing, network-visible issues	Deep — checks actual installed package versions, patch levels, local misconfigs
Accuracy	More false positives, misses local issues	Far more accurate, the "real" picture of a host's risk
Real-world use	Simulates external attacker	Simulates insider threat / post-compromise / true patch compliance

Practical takeaway: a credentialed scan is what real internal VAPT engagements rely on for accurate findings — an unauthenticated scan alone dramatically understates actual risk, since it can't see what's installed, only what's exposed.

4. Basic Workflow

1. Install Nessus, activate with an Essentials/Pro key
2. Create a new scan → choose a template (Basic Network Scan, Advanced Scan, etc.)
3. Set target(s) — single IP, range, or CIDR
4. (Optional but recommended) Add credentials — SSH keys/passwords for Linux, domain creds for Windows
5. Launch scan
6. Review results — sorted by severity (Critical/High/Medium/Low/Info)
7. Export report (PDF/CSV/Nessus native format)

5. Scan Templates Worth Knowing

Template	Use Case
Basic Network Scan	General-purpose, good default starting point
Advanced Scan	Full manual control over every plugin family
Web Application Tests	Focused on web app vulns (though dedicated tools like ZAP/Nuclei often do this better)
Malware Scan	Checks for known malware signatures on hosts
Policy Compliance Auditing	Checks against CIS benchmarks, PCI-DSS, etc. — relevant to SOC/compliance-adjacent roles

6. Reading Nessus Output — Severity and CVSS

Every finding includes:

- **Plugin ID** — Nessus's internal identifier for the specific check
- **Severity** — Critical / High / Medium / Low / Info, derived from CVSS score
- **CVSS Base Score** — standardized severity score (covered in depth in your CVSS guide)
- **Description** — what the vulnerability is
- **Solution** — the remediation (usually: apply patch X, or reconfigure Y)
- **Plugin Output** — the exact evidence Nessus found (e.g., the specific vulnerable version string detected)

```
Example finding:
[Critical] MS17-010: SMB Remote Code Execution (EternalBlue)
CVSS: 9.3
Solution: Apply the vendor patch or disable SMBv1
```

This is exactly the same vulnerability your NSE guide's `smb-vuln-ms17-010` script checks for — Nessus just runs thousands of checks like this simultaneously, automatically, with a polished report at the end.

7. Practical Lab Example

1. Point Nessus Essentials at your Metasploitable 2 VM
2. Run a Basic Network Scan (unauthenticated first)
3. Compare results against what you already found manually via Nmap/NSE/Enum4linux in earlier study sessions
4. Add credentials (msfadmin/msfadmin) and re-scan
5. Compare the credentialed vs uncredentialed result count/depth

This comparison exercise is genuinely one of the best ways to *feel* the difference credentialed scanning makes — Metasploitable 2 is specifically built to expose dozens of findings, so the contrast will be obvious.

8. Nessus in a VAPT Workflow

Manual recon (Nmap/NSE/Enum4linux/SMBMap)	→ targeted, understood findings
+	
Nessus automated scan recon might miss	→ broad coverage, catches what manual
↓	
Cross-reference and validate	→ automated tools produce false

↓ positives; manual verification matters
Prioritize by CVSS/exploitability → feeds into your report's risk ranking

Important professional norm: Nessus findings should never be pasted directly into a report without validation — false positives happen, and a credible VAPT report demonstrates the finding was manually confirmed, not just "the scanner said so."

9. Kill Chain / ATT&CK Mapping

Framework	Mapping
Cyber Kill Chain	Reconnaissance (identifies what's exploitable, informs Weaponization)
MITRE ATT&CK	T1595.002 (Active Scanning: Vulnerability Scanning)

Quick Reference Cheat Sheet

Free tier: Nessus Essentials (16 IPs)
Scan types: Basic Network Scan, Advanced Scan, Policy Compliance
Credentialed scanning >> uncredentialed for accuracy
Output: Plugin ID, Severity, CVSS score, Solution, Plugin Output
Always manually validate before reporting